

PrimeHealth Clinic & Diagnostic

Information Security Risk Assessment

Document Version History

Date	Version	Updated By	Details of Change	Approved By
10/08/2024	1.0	Whole Team	Basic Draft of document	Executive Team
19/9/2024	1.0	Whole Team	Draft in progress	Executive Team
01/10/2024	1.0	Whole Team	Draft sent for review	Executive Team
24/10/2024	1.0	Whole Team Aaron (CEO)	Document approved and published	Executive Team

Table of Content

1.	Purpose	1
2.	Scope.....	1
3.	Objectives	1
4.	Risk Assessment Process	1
a.	Identification of Information Assets	1
b.	Threat and Vulnerability Identification	1
c.	Risk Analysis and Evaluation.....	1
d.	Documentation:	1
5.	Responsibilities	1
6.	Review and Updates	1
7.	Supporting reference and evidence documents	1

1. Purpose

The purpose of this document is to establish a formal process for the identification, evaluation, and documentation of risks to Prime Healthcare's information assets. This process ensures the protection of confidentiality, integrity, and availability of the company's sensitive data in compliance with applicable legal and regulatory standards.

This document supports the overall ISMS objectives by ensuring consistent and effective risk management practices.

2. Scope

This document applies to PrimeHealth's business processes and information assets that impact the organization's information security.

3. Objectives

The objectives of this document are to:

- Identify and document information security risks, threats and vulnerabilities that may impact the Prime Health's information asset.
- Assess the potential impact and likelihood of the identified risks against each information asset
- Prioritizing and analyzing the risk based on their potential impact on the company
- Ensure that all identified risks are regularly reviewed, reassessed, and monitored as part of a continuous improvement process.
- Ensure compliance with ISO/IEC 27001 and all other applicable legal and healthcare regulations

4. Risk Assessment Process

PrimeHealth's risk assessment process is developed in accordance with ISO 27005/ISO 31000 standards to ensure that all significant risks are identified, evaluated, and managed effectively. The process includes the following steps:

a. Identification of Information Assets

Each department identifies and records its critical information assets within the business processes. This data is recorded in the BPs & Information Asset sheet within the [ISO27K1_8.2] Business Processes, Information Assets & Risks Register.

b. Threat and Vulnerability Identification

All potential threats and vulnerabilities against PrimeHealth's information assets must be identified and cataloged. A detailed description of each type of threat—including how and where it will occur—has been recorded for each information asset.

c. Risk Analysis and Evaluation

- Risk analysis should be performed by assessing the likelihood and impact of each identified risk. Likelihood is determined based on the Annual Rate of Occurrence of a particular threat, while impact is assessed in financial terms. The risk value is then calculated based on these factors for each threat against an information asset.
- The risk rating is derived using the risk value identified in the previous step with the company's management-approved consequence table. This table is created through structured consultations with management to establish risk assessment terminologies and response strategies, as outlined in the 'What Would Management Do?' (WWMD) protocol. The Consequence Table is regularly reviewed and updated only after management's approval to ensure it aligns with the organization's strategic objectives and enhances risk management efficacy.
- The company's risk appetite is determined through structured consultations with key stakeholders, assessing the level of risk the organization is willing to accept in pursuit of its strategic objectives. PrimeHealth deems any risks above a 'minor' level unacceptable for the company.

d. Documentation:

All findings, analysis, and evaluations will be thoroughly documented in the Company's Risk Register.

5. Responsibilities

- Information Security Officer & Risk Officer: Oversee the risk assessment process and ensure compliance with this policy.
- Department Heads: Ensure that their respective departments comply with the risk assessment procedures.
- All Employees: Participate in the risk assessment process and report security concerns to the Information Security Officer.

6. Review and Updates

This document and all associated procedures will be reviewed annually or in response to significant changes in the business or IT environment. Updates will be made as necessary to ensure the continued relevance and effectiveness of the risk assessment process.

7. Supporting reference and evidence documents

- [ISO27K1_8.2] Business Processes, Information Assets & Risks Register
 - BPs & Information Assets
 - Threats
 - TRA
 - Consequence Table
 - WWMD
- List of Standards, Frameworks and Legislation
- [ISO27K1-4.3] ISMS Scope Statement
- [ISO27K1_9.3] ISMS Management Review
- ISO 27001 Clause 6.1.2 Information Security Risk Assessment (<https://hightable.io/iso-27001-clause-6-1-2-information-security-risk-assessment-guide/>)